

Table of Contents

Cisco Secure Workload — DORA (Digital Operational Resilience Act)

Reference Design | EU Financial Entities & Critical ICT Third-Party Providers

Version: 1.0 | **Standard:** Regulation (EU) 2022/2554 — DORA | **Effective:** 17 January 2025 | **Environment:** Hybrid

Reader's Guide

Who this is for. EU financial entities in scope of DORA — credit institutions, payment & e-money institutions, investment firms, CCPs, trading venues, insurers, crypto-asset service providers, crowdfunding service providers — and the critical ICT third-party providers (CTPPs) that serve them. Also useful for the security architects and ICT risk officers preparing those organisations for their competent-authority engagement.

Questions this reference design helps you answer:

- *Article 8 — ICT Risk Management Framework: can I produce a current inventory view of CSW-covered ICT assets supporting "important business functions" (IBFs), classified by criticality, and reconcile it with the authoritative enterprise ICT asset register?*
- *Article 9(2) — protection and prevention: for each IBF, can I demonstrate that network segmentation between supporting systems is enforced and continuously verified, not just designed?*
- *Article 10 — detection: when an anomalous workload-to-workload flow appears inside an IBF (e.g., a payments service starts talking to a general ledger system it never touched before), is it detected, and what is the artefact?*
- *Article 17 — ICT-related incident management: when a major incident occurs, can I reconstruct the exact process and flow context at the time of compromise to support the 4h/24h/72h/1-month reporting cadence under Article 19?*
- *Article 24–25 — digital operational resilience testing (TLPT, threat- led penetration testing): can red teams run TIBER-EU style exercises against my environment, and can I produce the workload-level evidence (lateral movement attempts, segmentation holds, detections) the testers and the lead competent authority will ask for?*
- *Article 28 — ICT third-party risk: do I actually know which third- party (CTPP) services my critical workloads call out to, on what ports, with what frequency — independent of what the contract says?*

- *If my lead competent authority requests under Article 50 the "results of testing" or "register of information" on third-party arrangements, what do I hand over from CSW within one business day?*

What you'll need. Your current ICT asset inventory, the list of "important business functions" your management body has approved (Article 8(4)), your current Register of Information for ICT third- party arrangements (Article 28(3)), your incident classification criteria under the RTS on classification of major incidents, and the list of competent and lead authorities applicable to your entity.

Where to start. Section 2 if you're scoping an IBF; sections 3–4 if you're building the ICT risk management framework artefacts; sections 5–6 if you're preparing for TLPT; section 7 if your incident response programme is the gap; section 9 if third-party visibility is the open item.

Important. DORA assigns ultimate accountability to the *management body* (Article 5). Nothing in this reference design substitutes for that governance. CSW gives the management body the *evidence* it needs to discharge that accountability with confidence; it does not discharge it on the body's behalf.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated

- ❑ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ❑ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ❑ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ❑ SIEM integration verified (sample events)
- ❑ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Art. 8/9 segmentation + ICT asset inventory from live scope
- Art. 19 incident dossier templates from flow/process export
- Art. 28 third-party egress from observed outbound flows

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

DORA harmonises the ICT risk management requirements for the EU financial sector across five pillars:

1. **ICT Risk Management** (Articles 5–16) — governance, risk framework, asset inventory, protection, detection, response, learning.
2. **ICT-Related Incident Management, Classification & Reporting** (Articles 17–23) — single harmonised reporting flow to competent authorities.
3. **Digital Operational Resilience Testing** (Articles 24–27) — including TLPT every 3 years for significant entities.
4. **Managing of ICT Third-Party Risk** (Articles 28–44) — register of information, contractual provisions, oversight of CTPPs by the ESAs.
5. **Information-Sharing Arrangements** (Article 45) — voluntary intelligence exchange between financial entities.

Where CSW fits. CSW is not an end-to-end DORA solution and does not address Pillars 4 (third-party contracts) or 5 (information sharing) directly. It does, however, provide the

workload-level evidence engine that Pillars 1, 2 and 3 increasingly require — and gives you measurable visibility into Pillar 4's *technical* exposure question ("what is my workload actually talking to that I don't control?").

DORA Pillar	CSW contribution
Pillar 1 — ICT Risk Management	Continuous workload inventory inputs (Art. 8), segmentation enforcement (Art. 9), behavioural detection (Art. 10), forensic flow data for response & learning (Arts. 11, 13).
Pillar 2 — Incident Management	Reconstructable process and flow timeline supporting initial, intermediate and final reports (Art. 19).
Pillar 3 — Resilience Testing	Workload-level evidence for vulnerability assessments and scenario-based tests (Art. 25(1)); attack-path data and segmentation telemetry for TLPT (Art. 26).
Pillar 4 — Third-Party Risk	Independent technical view of which third-party endpoints critical workloads call (complements but does not replace contractual register).
Pillar 5 — Information Sharing	Indicators-of-compromise and behavioural signatures derived from CSW telemetry can feed sectoral sharing arrangements.

2. Scoping — Important Business Functions (IBFs)

Article 8(4) requires entities to identify and classify ICT systems supporting "important business functions." Everything else in DORA escalates in stringency for these.

CSW Implementation:

Step 1: Get the management-body-approved IBF list

→ Typical examples (insert your own):

- Card payment authorisation
- SEPA credit transfer initiation
- Securities settlement
- Custody booking
- Trading order routing
- KYC / AML decisioning

Step 2: Label every workload that supports an IBF

CSW UI → Inventory → Bulk Label

Mandatory labels:

dora_ibf: true | false
ibf_name: [IBF identifier from management body register]
ibf_criticality: critical | important | supporting
data_class: personal | financial | confidential | internal
entity_legal: [legal entity in scope of DORA]

Step 3: Build an IBF Scope per business function

CSW UI → Organize → Scopes → New

Filter: ibf_name = "card-payment-auth" → Save scope

Repeat for each IBF

→ This becomes the unit of policy, evidence, and reporting

Step 4: Validate CSW coverage against the authoritative inventory baseline

→ Cross-check CSW inventory count vs. your CMDB / ServiceNow IBF view

→ Any delta = scoping risk; resolve before formal Art. 8 sign-off

Evidence: Per-IBF scope export (CSV) with workload count, OS, location, owner, last-seen timestamp.

3. Article 8 — ICT Asset Inventory

DORA Article 8(1) requires a current inventory of *all* ICT assets, including their interdependencies. Article 8(6) specifies it must be updated "periodically and on every significant change."

CSW Implementation:

Step 1: Achieve sensor coverage on every supported workload supporting an IBF

→ Linux: yum/dnf/apt + systemctl enable csw-agent

→ Windows: MSI install + service verification

→ Containers: DaemonSet sensor for K8s; per-node sensor for

ECS/AKS/GKE

→ Cloud: External Orchestrators (AWS/Azure/GCP) for asset metadata

Step 2: Configure interdependency capture (ADM)

CSW UI → Defend → Segmentation → ADM Run

Scope: each IBF Scope (run per-IBF, not all at once)

Duration: ≥ 14 days to capture month-end batch processes

Step 3: Schedule continuous inventory drift detection

CSW UI → Reports → Inventory → Schedule

Cadence: daily snapshot, weekly delta report

Owner: ICT Risk function (delegated under Art. 6(4))

Step 4: Wire the inventory feed to your Register of Information
→ API: /openapi/v1/inventory
→ Use: nightly export → reconcile against management's Register

Evidence: (a) current CSW inventory export with each covered workload's OS, hostname, IP, agent version, owner labels, last-check-in; (b) ADM dependency graph per IBF; (c) drift report showing additions/removals since the previous management-body review; (d) reconciliation notes for assets outside CSW coverage.

4. Article 9 — Protection and Prevention

Article 9(2) calls for "design, procurement and operation" of ICT systems that minimise impact, including segregation, monitoring and resilient configuration.

CSW Implementation — IBF Segmentation Pattern:

Step 1: Define the IBF policy workspace
CSW UI → Defend → Segmentation → New Workspace
Name: dora-ibf-{ibf_name}
Scope: ibf_name = {ibf_name}

Step 2: Use ADM to compute the as-observed policy
→ Run ADM on the workspace; review proposed clusters
→ Reject "noise" clusters; rename clusters to business roles
→ Clusters become policy intents

Step 3: Layer DORA-aligned hardening rules on top
DENY: Any IBF workload → Internet (egress) unless explicitly required
DENY: Non-IBF workloads → IBF workloads (cross-IBF lateral)
DENY: Plaintext protocols (HTTP/21/23/389) → IBF workloads
ALLOW: IBF workloads → approved CTPP egress endpoints (whitelist by FQDN/IP, with port + frequency constraint where supported)

Step 4: Run in Simulation for ≥ 30 days
→ Capture and resolve every legitimate-but-blocked flow with the application owner; document every exception in the workspace notes
→ This is the artefact that demonstrates "continuous review" required
under Art. 9(4)(g)

Step 5: Promote to Enforce; gate with change-management approval
→ Each subsequent change is captured in CSW change history
→ Evidence: enforcement diff report, exported per quarter

Evidence: (a) policy workspace export per IBF; (b) simulation → enforcement transition log; (c) quarterly enforcement diff report.

5. Article 10 — Detection

Article 10 requires detection of "anomalous activities, including ICT network performance issues and ICT-related incidents."

CSW Implementation:

Step 1: Enable behavioural detections

CSW UI → Defend → Forensics → Rules
→ Out-of-the-box rules: privilege escalation, persistence, lateral movement
→ Custom rules: encode IBF-specific abuse patterns
Example: "Process on payment-auth host writes to /etc/shadow"
Example: "Outbound TLS to non-allowlisted FQDN from settlement host"

Step 2: Enable Conversation-graph anomaly detection

→ Auto-flag new edges in the IBF dependency graph
→ Auto-flag changes in port/protocol distribution per workload

Step 3: Wire alerts to your SOC

CSW UI → Manage → Data Tap → SIEM
→ Splunk HEC, QRadar, Sentinel, Cisco XDR
→ Tag alerts with `dora_ibf=true` so SOC can prioritise per Art. 17

Step 4: Track detection latency (an Art. 11(2) lessons-learned input)

→ CSW timestamps every detection; SIEM timestamps acknowledgement
→ Compute MTTD per IBF; report to management body quarterly

Evidence: (a) detection rule catalogue with last-modified dates; (b) SIEM forwarding configuration; (c) MTTD trend report per IBF.

6. Article 11 — Response and Recovery

Article 11(2) requires "comprehensive ICT business continuity policy" including procedures for "containment, eradication and recovery."

CSW Implementation — Containment Playbook:

Scenario: SOC declares a confirmed compromise on workload W in IBF X

Step 1 (T+0): Quarantine W

CSW UI → Inventory → W → Apply Quarantine Policy
→ Pre-built policy: deny all, allow only IR jump-host on TCP/22
→ Typically applied in seconds without firewall change tickets

Step 2 (T+0): Pivot to other workloads in IBF X with similar exposure

→ Use CSW vulnerability + process inventory to identify peers running

the same software/version → preemptively quarantine if criticality warrants

Step 3 (T+5min): Capture forensic baseline

- CSW historical flow data: all conversations to/from W in last 30 days
- CSW process snapshot: every process running on W at containment
- CSW package inventory: every installed package and version
- Export to incident case; this is the Art. 11(2)(d) "post-incident review" raw material

Evidence: (a) quarantine policy applied (timestamped); (b) forensic export bundle; (c) containment-to-remediation timeline.

7. Articles 17–23 — Incident Management, Classification & Reporting

DORA harmonises incident reporting into one flow with three deadlines under Article 19 (subject to the implementing RTS on incident reporting):

Phase	Deadline (typical, confirm against final RTS)	Required content
Initial notification	As soon as possible, no later than 4 h after classification as major	Nature, type, root cause if known, geographic spread
Intermediate report	Within 72 h of initial	Updated facts, status of containment, impact estimates
Final report	Within 1 month of initial	Root cause analysis, remediation, lessons learned

CSW Implementation — Reporting Evidence:

For each major incident, assemble from CSW:

- Affected workload set
 - Inventory query: hostnames, IPs, OS, IBF labels, ownership
- Time-anchored flow record
 - CSW historical conversations: source, destination, port, byte counts, timestamps, geographic origin via flow context
- Process activity record
 - Every process spawned on affected workloads in the window
- Software footprint at time of incident
 - Package list, CVE exposure at that moment (not "today")
- Containment evidence
 - Policy applied; flow drop count after policy; time-to-

quarantine

(f) Post-incident control proof

→ Diff between pre-incident segmentation and remediated state

These six artefacts populate the standard incident report template your competent authority will accept.

Evidence: (a) incident dossier per major event; (b) MTTD/MTTR metrics by IBF; (c) annual aggregate incident-trend report (an Art. 13 "learning" input to the management body).

8. Articles 24–27 — Digital Operational Resilience Testing

Article 24 requires a sound and comprehensive testing programme. Article 25(1) lists baseline tests (vulnerability assessments, scenario-based, performance, end-to-end). Article 26 introduces TLPT (threat-led penetration testing) every 3 years for significant entities, modelled on TIBER-EU.

CSW Implementation — Baseline Test Support (Art. 25):

Vulnerability assessment:

- CSW Vulnerability Dashboard: per-workload CVE list with CVSS, exploit availability, EPSS score
- Filter by `ibf_ciricality=critical` → priority remediation queue
- Evidence: weekly export tied to remediation ticket IDs

Scenario-based testing:

- CSW supports "what-if" policy queries:
"If host X were compromised, which IBF Y workloads are reachable under current policy?"
- Use to validate segmentation assumptions before tabletop exercises
- Evidence: pre-test reachability report; post-test reachability report

CSW Implementation — TLPT Support (Art. 26):

Pre-engagement (with TIBER-EU lead):

- Scope selection: provide IBF inventory + dependency graph to red team
- Threat intel grounding: provide CSW outbound-flow patterns to scope realistic attacker pivots

During engagement:

- Red team operates blind; no CSW data shared in real time
- Defenders may be in "purple" mode if pre-agreed; CSW alerts can be observed but not acted on without authorised abort

Post-engagement:

- CSW timeline reconstruction: every flow attempted by red team,

- every detection generated, every block enforced
- Gap analysis: which Art. 9 segmentation rules held, which were bypassed, which detections fired vs. missed
- Evidence: full red-team activity reconstruction, comparable to the findings report – this is the artefact the lead authority and your management body will rely on most

Evidence: (a) Art. 25 test catalogue with results and remediation status; (b) per-TLPT engagement reconstruction package.

9. Articles 28–30 — ICT Third-Party Risk (Technical Lens)

DORA Pillar 4 is largely contractual and governance-driven (Articles 28(3)–(7), 30 contractual provisions, 31–44 CTPP oversight). CSW does *not* substitute for the Register of Information or for legal review. It does answer the technical companion question: *what are my critical workloads actually doing with third parties?*

CSW Implementation:

Step 1: Enumerate third-party egress per IBF

CSW UI → Investigate → Flow Search

Filter: source_scope = ibf_name=X AND destination_ip # internal_ranges

- Group by destination FQDN/IP; rank by byte count, frequency
- Output: technical view of third-party dependency per IBF

Step 2: Reconcile against the Register of Information

→ For each observed third-party endpoint, find the corresponding entry

in the Register; flag missing / undocumented endpoints

→ This is the *gap* between contracted and actual third-party usage

Step 3: Enforce egress allow-listing for IBF workloads

ALLOW: IBF workloads → {Register-listed third-party endpoints only}

DENY: IBF workloads → all other external destinations

→ Run in Simulation; resolve gaps; promote to Enforce

→ New third-party usage now requires Register update before deployment

Step 4: Continuous monitoring

→ CSW alert: "new external destination from IBF workload"

→ Routes to ICT Risk function for Register reconciliation within the cadence required under Art. 28(3)

Evidence: (a) per-IBF third-party flow report; (b) Register-vs- observed delta report; (c) egress policy enforcement diff history.

Important caveat. A CTPP's *internal* posture is out of scope for CSW unless that CTPP also runs CSW within its environment. Article 30 contractual provisions remain the primary control for CTPP behaviour outside your perimeter.

10. Article 13 — Learning and Evolving

Article 13 requires a continuous-improvement loop. The combination of incident metrics (§7), test outcomes (§8) and third-party drift findings (§9) produces a quarterly evidence pack the management body can use to discharge its Article 5 accountability.

Recommended quarterly pack contents:

1. IBF inventory drift summary
 2. Segmentation policy diff (changes, new exceptions, removed exceptions)
 3. Incident summary with MTTD/MTTR per IBF
 4. Vulnerability backlog aged by criticality
 5. Third-party egress drift summary
 6. Test programme status (Art. 25 baseline + Art. 26 TLPT cycle position)
 7. Open audit/competent-authority findings and remediation status
-

11. Mapping Table — DORA Article → CSW Capability

DORA Article	Requirement	CSW Capability
5	Governance & accountability	Quarterly evidence pack to management body (§10)
6	ICT risk management framework	Centralised inventory, policy and detection state
8(1)–(6)	ICT asset inventory	Continuous workload inventory + ADM dependency graph
9(2)(a)	Network segmentation	Per-IBF segmentation workspaces, simulation → enforce
9(2)(b)	Identification of unauthorised activities	ADM drift, conversation-graph anomalies
9(4)(g)	Continuous review of segmentation	Quarterly policy diff report
10	Detection	Behavioural rules + SIEM forwarding
11	Response and recovery	Quarantine policy +

DORA Article	Requirement	CSW Capability
		forensic export bundle
13	Learning and evolving	Quarterly metrics pack
17	Incident management process	Forensic timeline reconstruction
18	Classification of incidents	IBF labels + flow context inform classification
19	Reporting deadlines (4h / 72h / 1mo)	Six-artefact dossier (§7)
24	Testing programme	Vulnerability + scenario test evidence
25(1)	Baseline tests	CVE dashboard + reachability queries
26	TLPT	Red-team activity reconstruction
28(3)	Register of Information	Third-party egress reconciliation feed
28(4)	Third-party risk monitoring	Continuous outbound flow monitoring
30(2)(c)	Contractual right to monitor	Technical evidence supporting contractual right

12. Auditor / Competent-Authority Response Guide

When asked under Article 50 (information requests) for evidence:

Authority asks	You provide
"Show your IBF asset inventory as of [date]"	CSW inventory snapshot filtered by <code>dora_ibf=true</code> , dated
"Demonstrate segmentation between IBF A and IBF B"	Workspace export + Simulation run showing zero allowed flows between scopes
"Provide the incident timeline for event [ID]"	Six-artefact dossier (§7)
"Show how you monitor third-party drift"	Register-vs-observed delta report (§9)
"Provide the TLPT remediation evidence"	Pre/post reachability reports + workspace diff + detection rule additions

13. Related Frameworks

DORA shares substantial control surface with:

- **NIS2** — many of the Article 21(2) measures overlap with DORA Pillars 1–2 (see [NIS2 reference design](#)).
 - **ISO/IEC 27001:2022** — Annex A controls map cleanly to DORA Pillar 1 (see [ISO 27001 reference design](#)).
 - **NIST SP 800-207** — DORA's segmentation and continuous-monitoring expectations align with the seven ZTA tenets (see [800-207 reference design](#)).
 - **PCI DSS v4.0** — for payment-services entities, DORA Pillar 1 and PCI Reqs 1, 7, 10, 11 share evidence (see [PCI reference design](#)).
 - **UK NCSC CAF v3.2** — Art. 28 and Art. 19 are the reuse path for CAF A4 and D1 (see [CAF crosswalk](#)).
-

14. Disclaimer

This reference design describes how Cisco Secure Workload capabilities can support a DORA programme. It is **not** legal advice and does not constitute a finding of compliance. Final classification of incidents, identification of "important business functions," determination of TLPT applicability, and contractual obligations under Articles 28–30 are the responsibility of the financial entity's management body and its qualified legal and compliance counsel, working with the relevant competent authority. Always validate against the latest published RTS and ITS and against any guidance issued by your lead overseer.